

EMCALI Cyber 2.0 Híbrido Enterprise

Plataforma inteligente para gestión de vulnerabilidades con IA generativa, RAG e inferencia híbrida local-nube

Edición consolidada V12 - Figuras 1-10 normalizadas; Figuras 8-10 actualizadas para la baseline APROBADA Y ESTABLE.

Rubén Darío Sabogal Urbano
Proyecto III - Universidad Icesi
Cali, Colombia - 2026

RESUMEN

EMCALI Cyber 2.0 Híbrido Enterprise es un prototipo de gestión defensiva de vulnerabilidades orientado a consolidar hallazgos técnicos, enriquecerlos con inteligencia pública, priorizar el riesgo y asistir la remediación mediante modelos de lenguaje. La solución integra fuentes como NVD/CVE/CVSS, CISA KEV, EPSS y resultados provenientes de plataformas de escaneo; normaliza los hallazgos en un conjunto de datos activo y los distribuye a módulos de análisis LLM, riesgo, remediación, RAG, informes y métricas. El diseño adopta una estrategia local-first mediante Ollama y modelos livianos, con fallback controlado hacia servicios de nube cuando la política y la disponibilidad lo permiten. Se incorporan recuperación aumentada por generación (RAG), trazabilidad del hallazgo, monitoreo de recursos y comparación de ejecución en hardware heterogéneo. El trabajo demuestra la viabilidad arquitectónica de una plataforma híbrida que reduce dependencia de proveedores externos, preserva la capacidad de operación local y estructura un flujo reproducible desde la ingesta hasta el cierre y reescaneo. Como trabajo futuro se plantea fortalecer ground truth, evaluación cuantitativa, MLOps, CI/CD, pruebas de carga e integración empresarial con SIEM/SOAR/XDR.

Índice de términos - Ciberseguridad, gestión de vulnerabilidades, IA generativa, LLM, Ollama, RAG, CVSS, EPSS.

I. INTRODUCCIÓN

La gestión de vulnerabilidades en una empresa de servicios públicos exige transformar grandes volúmenes de hallazgos en decisiones priorizadas, trazables y accionables. El problema no consiste únicamente en detectar CVE: es necesario relacionar severidad técnica, probabilidad de explotación, evidencia de explotación conocida, criticidad del activo, exposición e impacto operacional.

EMCALI Cyber 2.0 Híbrido se desarrolló para automatizar ese ciclo con una arquitectura que combina analítica determinística e inteligencia artificial generativa. Su propósito es apoyar al analista, no sustituir los controles técnicos: la IA sintetiza contexto, propone acciones y explica prioridades, mientras el motor de riesgo conserva variables verificables y la trazabilidad de las fuentes.

El aporte diferenciador es la inferencia híbrida. El procesamiento puede mantenerse local con Ollama, reduciendo exposición de información sensible y dependencia de conectividad, y escalar de forma controlada a modelos cloud mediante fallback. A ello se suma RAG para recuperar conocimiento técnico pertinente antes de generar recomendaciones.

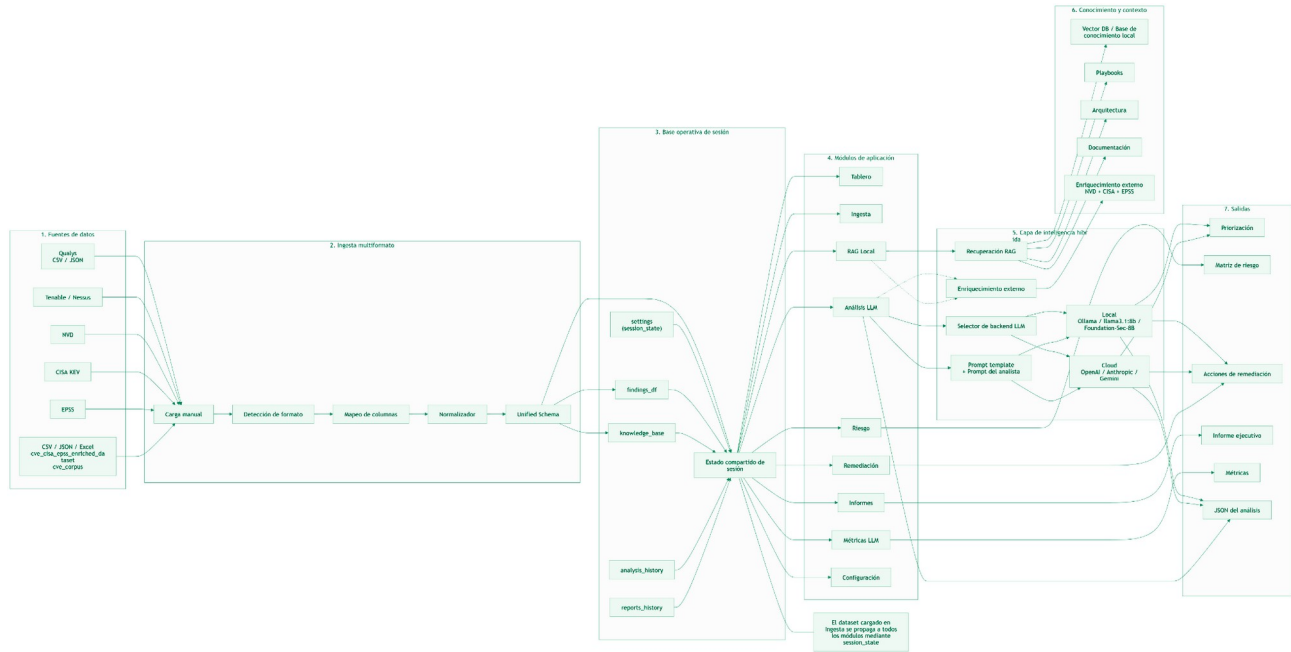


Fig. 1. Modelo único de arquitectura de EMCALI Cyber 2.0 Híbrido Enterprise.

II. MATERIALES Y MÉTODOS

A. Arquitectura y flujo de datos

La arquitectura se organiza en seis capas funcionales: fuentes de vulnerabilidades e inteligencia; ingesta y normalización; motor LLM; motor de riesgo; remediación y conocimiento RAG; y visualización/reportes. El dataset activo compartido evita que cada módulo opere sobre datos de demostración aislados y permite mantener continuidad analítica entre detección, análisis, priorización y cierre.

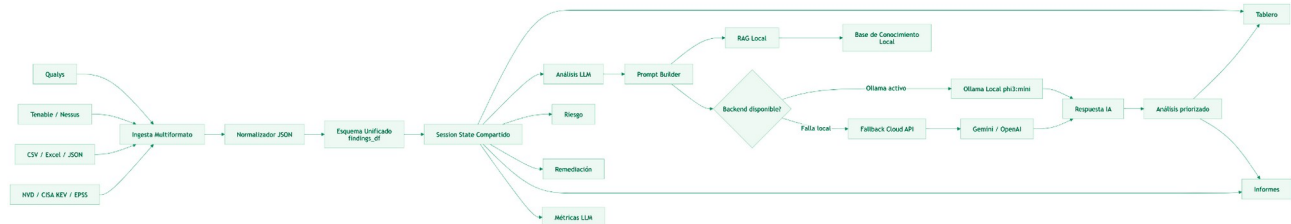


Fig. 2. Flujo de datos desde fuentes de vulnerabilidades hasta análisis, riesgo y remediación.

B. Fuentes y normalización

TABLA I. FUENTES DE DATOS E INTELIGENCIA

Fuente	Dato principal	Uso en EMCALI Cyber 2.0
NVD / CVE	Identificador, descripción, CVSS	Contexto técnico y severidad
CISA KEY	Explotación conocida	Aumenta prioridad operativa
EPSS	Probabilidad de explotación	Priorización probabilística
Tenable / Qualys / OpenVAS	Hallazgos de escaneo	Inventario técnico de vulnerabilidades
CSV / JSON / Excel	Intercambio y cargas externas	Ingesta multiformato

Durante la ingesta se homogenizan campos como identificador CVE, activo, dirección, servicio, severidad, CVSS, EPSS, estado KEV, evidencia, criticidad y recomendación. La normalización permite que los módulos posteriores consuman una estructura consistente.

C. Motor de riesgo

La priorización propuesta combina CVSS, EPSS, presencia en KEV, criticidad del activo, exposición e impacto. En el desarrollo previo se definió una ponderación de referencia de 25 %, 20 %, 20 %, 15 %, 10 % y 10 %, respectivamente. Esta ponderación es configurable y debe calibrarse con datos históricos y criterios de negocio antes de considerarse un modelo productivo.

TABLA II. MODELO MULTICRITERIO DE PRIORIZACIÓN

Variable	Peso de referencia	Interpretación
CVSS	25 %	Severidad técnica
EPSS	20 %	Probabilidad de explotación
CISA KEV	20 %	Explotación conocida
Criticidad	15 %	Importancia del activo
Exposición	10 %	Superficie/alcance
Impacto	10 %	Consecuencia operacional

D. Inferencia híbrida y modelos

El backend local utiliza Ollama, detección automática de modelos y health check. La versión estabilizada adoptó phi3:mini como configuración operativa para equipos de recursos limitados, manteniendo alternativas como Llama 3.1, Mistral y modelos especializados. El flujo de contingencia contempla ejecución local y fallback cloud controlado hacia Gemini y OpenAI.

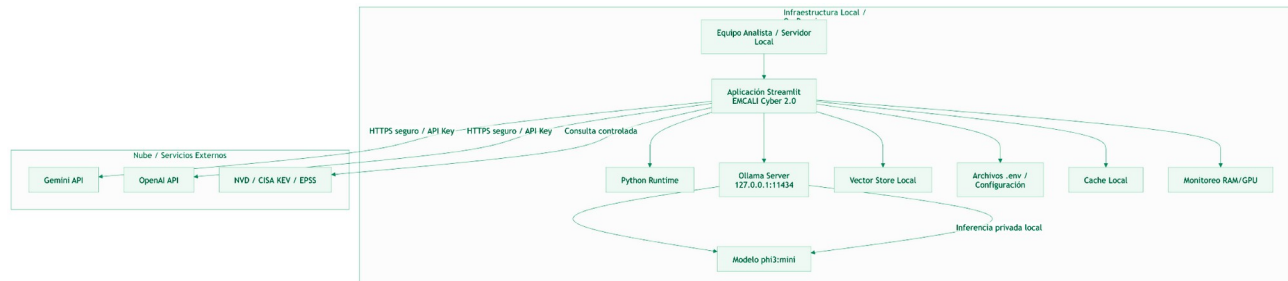


Fig. 3. Despliegue híbrido local-nube y rutas de inferencia.

E. Recuperación aumentada por generación (RAG)

RAG incorpora una base de conocimiento local y recuperación semántica para suministrar contexto relevante al modelo antes de generar una respuesta. El objetivo es disminuir respuestas genéricas y vincular recomendaciones con procedimientos, estándares, advisories y conocimiento técnico autorizado.

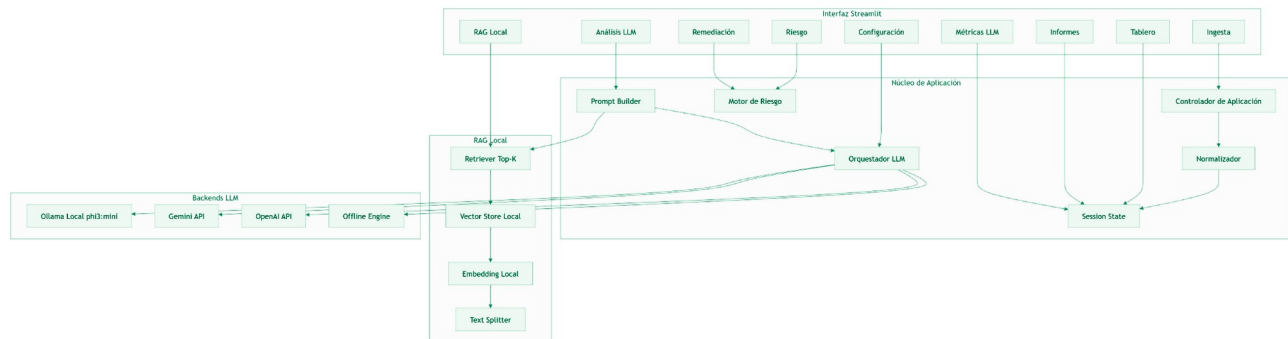


Fig. 4. Componentes del subsistema RAG.

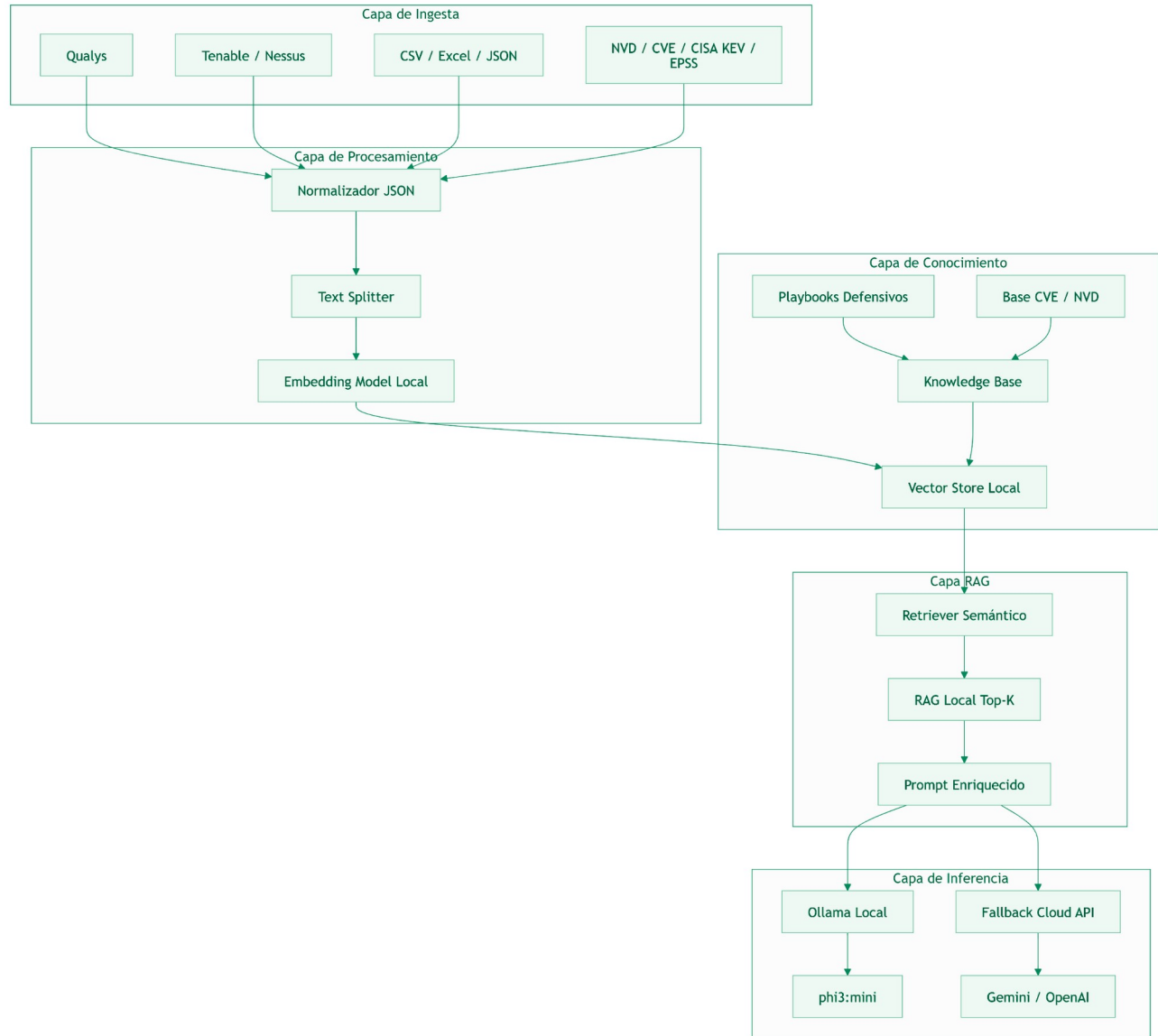


Fig. 5. Arquitectura del componente RAG local.

F. Secuencia de análisis

El ciclo comienza con la selección de un hallazgo normalizado. El sistema enriquece el contexto, calcula riesgo, recupera conocimiento RAG, selecciona el backend disponible, construye el prompt y genera una explicación técnica y acciones sugeridas. La salida se conserva para informes, métricas y trazabilidad.

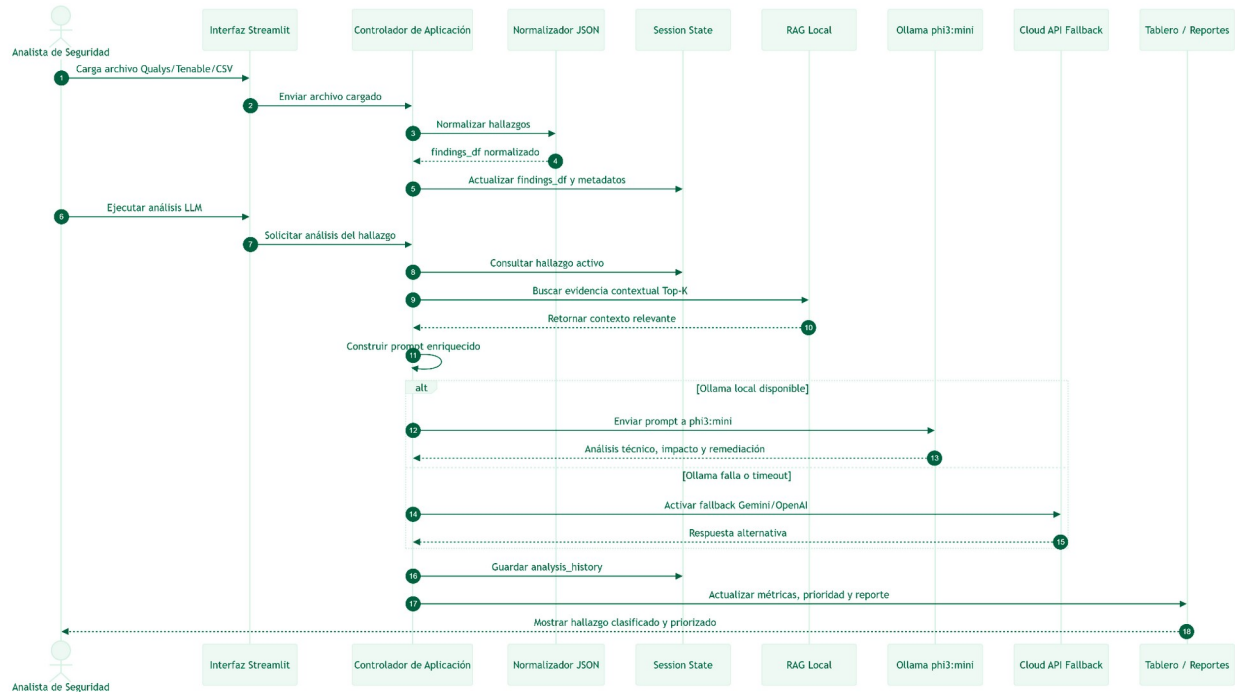


Fig. 6. Secuencia de análisis de una vulnerabilidad.

G. Implementación

TABLA III. STACK TECNOLÓGICO DEL PROTOTIPO

Componente	Tecnología / función
Interfaz	Python + Streamlit
Procesamiento	Pandas / JSON
LLM local	Ollama
LLM cloud	Gemini / OpenAI, según configuración
RAG	Embeddings + FAISS/ChromaDB
Persistencia	SQLite / archivos estructurados
Visualización	Plotly / tablas ejecutivas
Empaquetado	Windows portable / instalador

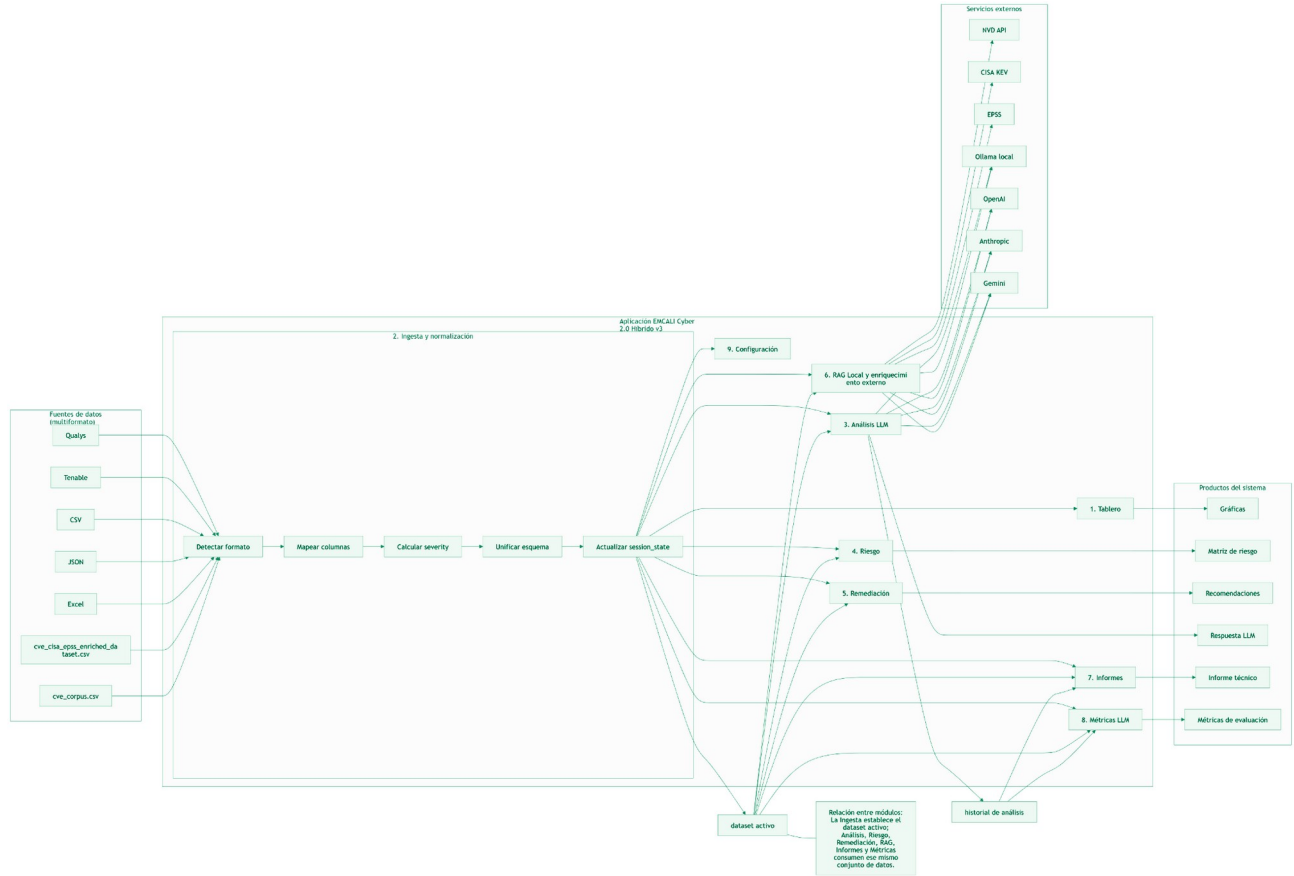


Fig. 7. Topología funcional y módulos internos.

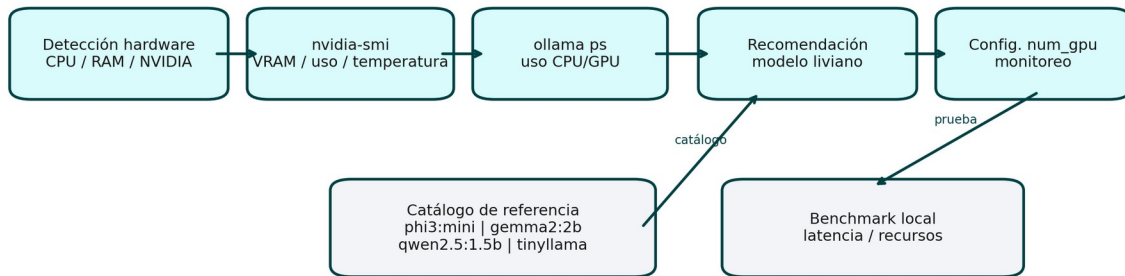
III. RESULTADOS

A. Módulos funcionales

El prototipo consolidó los módulos Tablero, Ingesta, Análisis LLM, Riesgo, Remediación, RAG Local, Informes, Métricas y Configuración. La evolución principal consistió en enlazarlos mediante un dataset activo compartido, de modo que la información cargada en Ingesta alimenta las demás vistas.

Figura 8. Diagnóstico de aceleración IA/GPU y selección de modelos en V12

Detección de hardware, telemetría Ollama y recomendación de modelos livianos



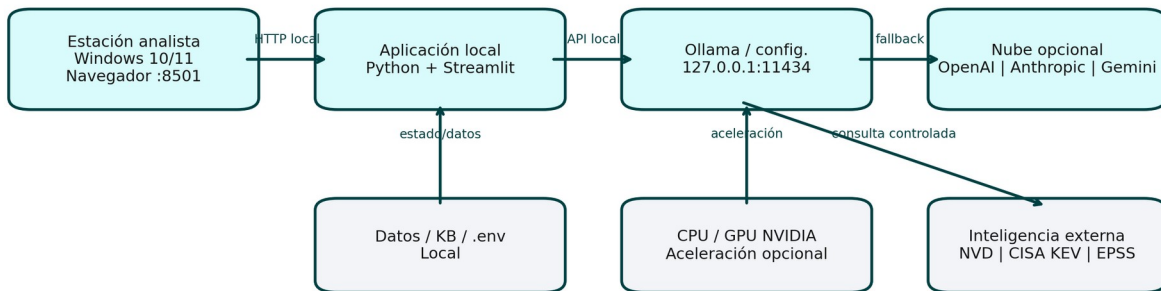
Objetivo: comprobar capacidad de inferencia local y seleccionar un modelo acorde con RAM/VRAM, manteniendo la ruta local como referencia operativa de V12.

EMCALI Cyber 2.0 Híbrido V12 | Baseline APROBADA Y ESTABLE | 2026

Fig. 8. Diagnóstico de aceleración IA/GPU y selección de modelos livianos en EMCALI Cyber 2.0 Híbrido V12.

Figura 9. Despliegue on-premise e híbrido de EMCALI Cyber 2.0 V12

Aplicación local-first con Ollama y servicios externos opcionales



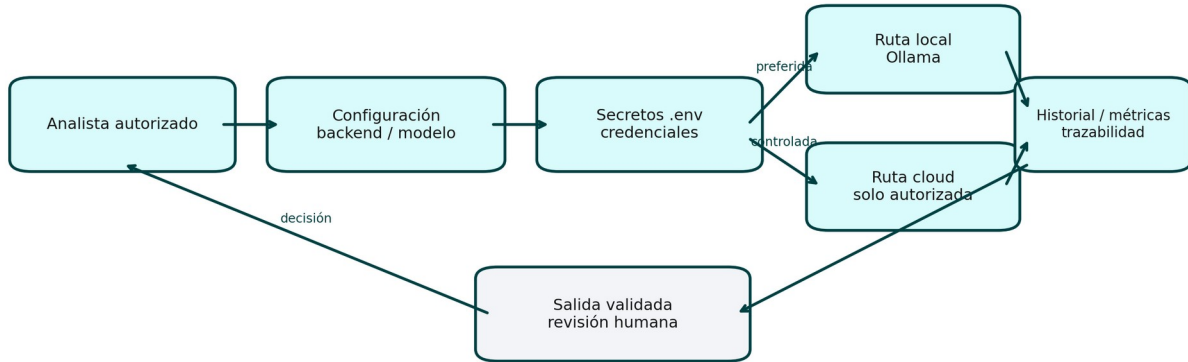
Principio de despliegue: operación local preferente; la nube y las fuentes externas se utilizan de forma controlada según configuración, disponibilidad y política de seguridad.

EMCALI Cyber 2.0 Híbrido V12 | Baseline APROBADA Y ESTABLE | 2026

Fig. 9. Despliegue on-premise e híbrido de EMCALI Cyber 2.0 Híbrido V12.

Figura 10. Seguridad y gobernanza de inferencia en la baseline V12

Control de backend/modelo, credenciales, rutas de inferencia, trazabilidad y revisión humana



Gobernanza V12: las credenciales se mantienen separadas de la lógica de aplicación; la ruta local es preferente, el uso cloud requiere autorización/configuración y toda salida técnica permanece sujeta a revisión humana.

EMCALI Cyber 2.0 Híbrido V12 | Baseline APROBADA Y ESTABLE | 2026

Fig. 10. Seguridad y gobernanza de inferencia de la baseline V12 aprobada y estable.

B. Comparación temporal del proceso

En las pruebas documentadas del proyecto se reportó un orden de magnitud de 10-30 min para análisis manual por vulnerabilidad frente a aproximadamente 10-60 s asistidos por EMCALI Cyber 2.0, mientras el análisis masivo pasa de horas o días a minutos. Estos valores corresponden al prototipo y deben interpretarse como evidencia experimental del entorno evaluado, no como SLA productivo.

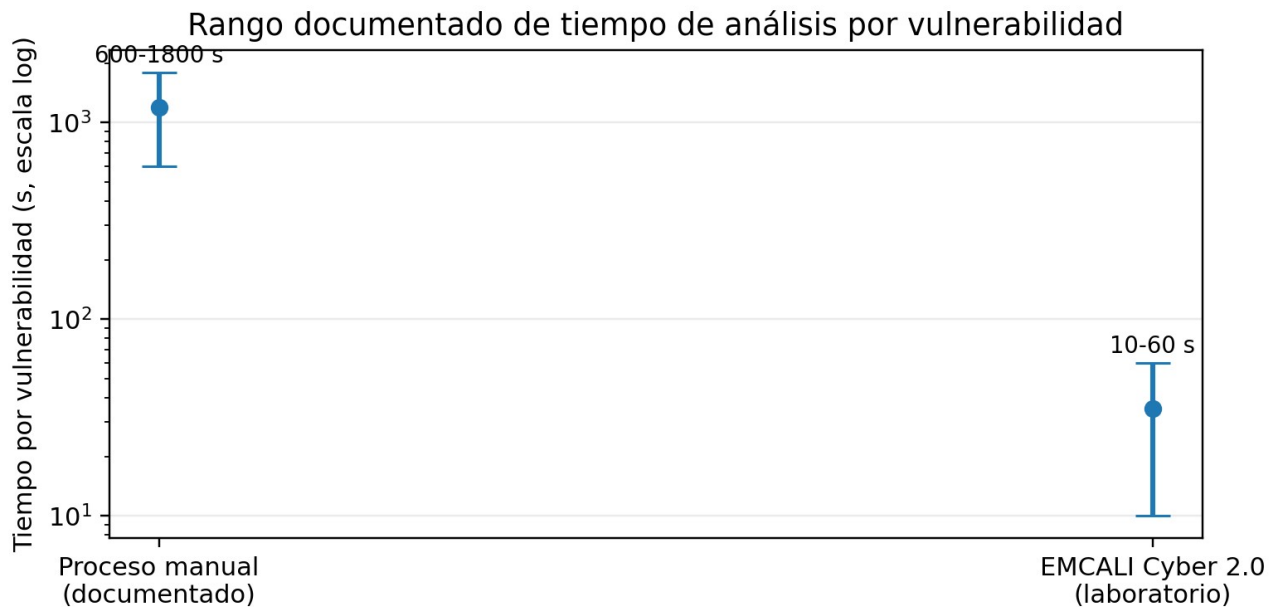


Fig. 11. Comparación documentada del tiempo de análisis manual frente al flujo asistido.

C. Hardware y capacidad de inferencia

Las pruebas se realizaron sobre equipos heterogéneos, incluyendo Lenovo ThinkPad X230, Dell Precision T1650 y HP Z600. Esta diversidad permitió observar la relevancia de RAM, VRAM y selección del modelo para la viabilidad de inferencia local.

Plataformas de validación del prototipo

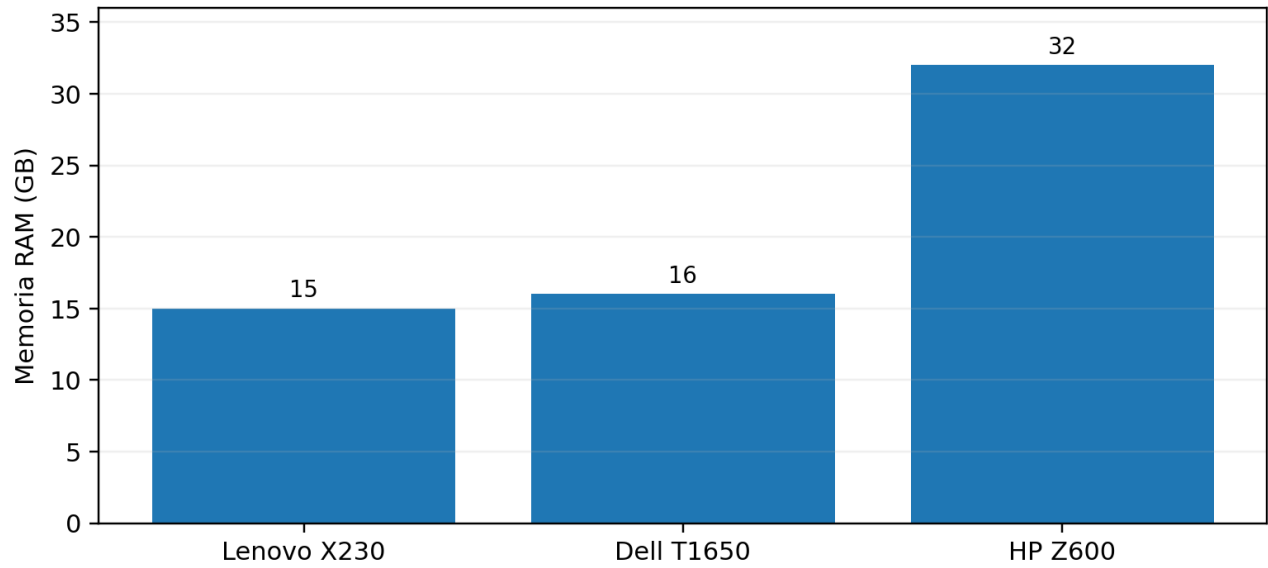


Fig. 12. Memoria RAM de plataformas utilizadas en pruebas.

GPU consideradas para inferencia local y pruebas

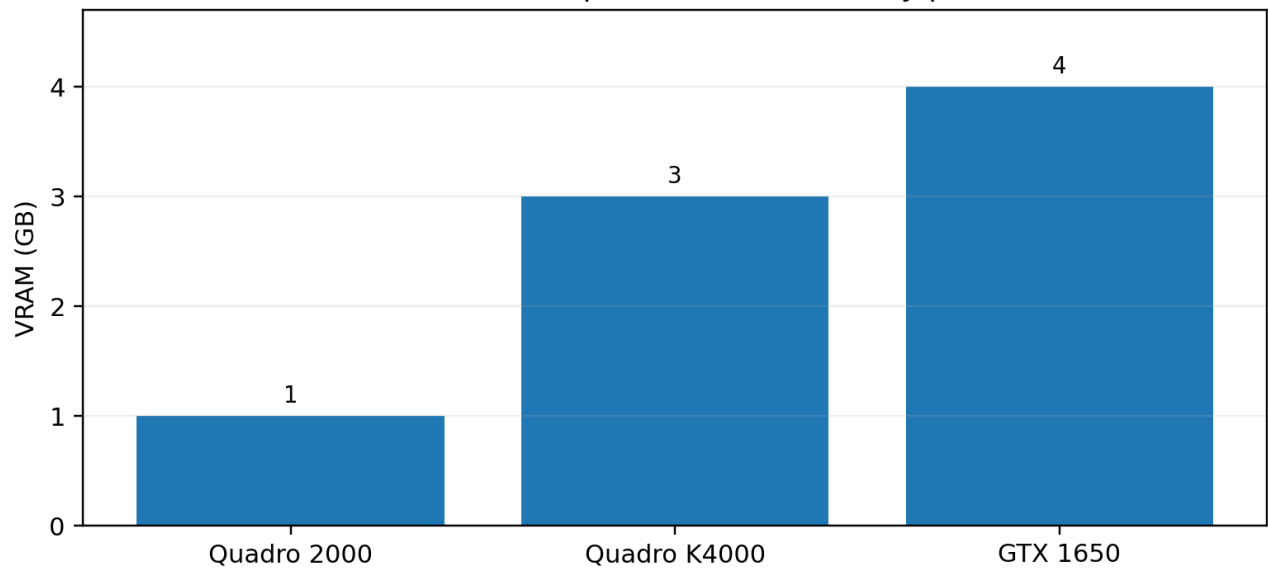


Fig. 13. VRAM disponible en configuraciones GPU consideradas.

D. Evolución del prototipo

TABLA IV. EVOLUCIÓN FUNCIONAL RELEVANTE

Versión	Aporte principal
V11	Base funcional consolidada
V12	Aceleración GPU, modelos livianos, Ollama robusto y fallback
V13	V12 preservada + Performance Lab para pruebas de rendimiento

E. Evidencia frente a Proyecto III

TABLA V. TRAZABILIDAD TÉCNICA DEL PROYECTO

Criterio	Evidencia incorporada	Estado
----------	-----------------------	--------

Arquitectura	Capas, componentes, secuencia y despliegue	Cumplido
Datos	Ingesta, normalización y fuentes externas	Cumplido
IA aplicada	LLM local/cloud + RAG	Cumplido
Prototipo	Módulos integrados y flujo end-to-end	Cumplido
Evaluación	Tiempo, recursos y Performance Lab	Avanzado
MLOps/CI-CD	Diseño y ruta de implementación	Pendiente de cierre productivo
Validación cuantitativa	Requiere ground truth y benchmark repetible	Pendiente

IV. DISCUSIÓN

Los resultados apoyan la viabilidad de una arquitectura local-first para gestión asistida de vulnerabilidades. El beneficio principal no es únicamente la velocidad: la plataforma centraliza fuentes heterogéneas, hace explícita la priorización y conserva la posibilidad de operar sin depender totalmente de servicios externos.

El uso de RAG es especialmente relevante porque la gestión de vulnerabilidades requiere respuestas contextualizadas. Sin embargo, RAG no elimina por sí mismo el riesgo de alucinación; la calidad depende del corpus, recuperación, versionado y evaluación. Por ello, las recomendaciones de remediación deben mantenerse bajo revisión humana.

La principal limitación metodológica es la falta de un ground truth suficientemente amplio y validado por especialistas para medir precisión, consistencia y calidad de remediación con intervalos de confianza. También permanecen como trabajo de maduración las pruebas de carga, RBAC, gestión empresarial de secretos, observabilidad, CI/CD y MLOps.

Desde el punto de vista de EMCALI, la arquitectura híbrida aporta soberanía operativa: permite mantener análisis local de información sensible y usar nube de forma selectiva. Para un eventual paso a producción, la solución deberá integrarse con gobierno de seguridad, segregación IT/OT, gestión de cambios, inventario de activos y controles del SGSI.

V. CONCLUSIONES

- EMCALI Cyber 2.0 Híbrido materializa un flujo end-to-end que conecta ingesta, enriquecimiento, análisis LLM, riesgo, remediación, RAG, informes y métricas.
- La inferencia local mediante Ollama es técnicamente viable y permite reducir dependencia de nube; la selección de modelos livianos es determinante en hardware con recursos limitados.
- El modelo híbrido mejora resiliencia operativa al disponer de rutas locales y fallback controlado, sin convertir la nube en requisito obligatorio.
- RAG aporta contexto técnico recuperable y trazable, pero requiere corpus gobernado y evaluación formal.
- El motor multicriterio CVSS-EPSS-KEV-criticidad-exposición-impacto ofrece una base explicable para priorización, pendiente de calibración con evidencia histórica.
- El siguiente nivel de madurez debe concentrarse en benchmark reproducible, ground truth, MLOps, CI/CD, seguridad de secretos, pruebas de carga e integración SIEM/SOAR/XDR.

APÉNDICE A. PLAN DE VALIDACIÓN PARA NIVEL AVANZADO

TABLA VI. CIERRE DE BRECHAS DE VALIDACIÓN

Actividad	Métrica / evidencia esperada
Dataset de referencia	CVE/hallazgos etiquetados y validados por expertos
Benchmark LLM	Latencia, tokens, RAM/VRAM, consistencia y calidad
Evaluación RAG	Precision@k, Recall@k, groundedness y revisión humana
Pruebas de carga	Usuarios concurrentes, throughput, p95/p99
MLOps	Versionado de modelo, prompt, corpus y configuración

CI/CD	Build, pruebas, análisis de seguridad y despliegue reproducible
Seguridad	RBAC, secretos, auditoría y segregación de ambientes

REFERENCIAS

- [1] ISO/IEC, ISO/IEC 27001:2022, Information security management systems - Requirements, 2022.
- [2] NIST, Cybersecurity Framework (CSF) 2.0, National Institute of Standards and Technology, 2024.
- [3] NIST, SP 800-40 Rev. 4, Guide to Enterprise Patch Management Planning, 2022.
- [4] FIRST, Common Vulnerability Scoring System (CVSS) v4.0 Specification, 2023.
- [5] FIRST, Exploit Prediction Scoring System (EPSS), documentation and model.
- [6] CISA, Known Exploited Vulnerabilities Catalog.
- [7] NIST, National Vulnerability Database (NVD).
- [8] MITRE, Common Vulnerabilities and Exposures (CVE) Program.
- [9] OWASP Foundation, OWASP Top 10 and vulnerability management resources.
- [10] Ollama, Documentation for local large language model execution.
- [11] P. Lewis et al., "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," NeurIPS, 2020.
- [12] T. Brown et al., "Language Models are Few-Shot Learners," NeurIPS, 2020.
- [13] Meta AI, Llama 3 model documentation.
- [14] Microsoft, Phi-3 Technical Report, 2024.
- [15] Mistral AI, Mistral model documentation.
- [16] CISA, Cybersecurity Performance Goals and vulnerability remediation guidance.
- [17] NIST, AI Risk Management Framework (AI RMF 1.0), 2023.
- [18] ISO/IEC, ISO/IEC 23894:2023, Artificial intelligence - Guidance on risk management.
- [19] MITRE, CWE - Common Weakness Enumeration.
- [20] MITRE, ATT&CK Knowledge Base.